**Internal Security Audit Report for Botium Toys**

## 1. Audit Scope and Goals

**Scope:** The scope of this audit includes a comprehensive review of Botium Toys' security program, covering all IT assets, internal processes, and compliance controls. The assessment focuses on:

- IT infrastructure security
- Employee access controls
- Data protection measures
- Regulatory compliance (PCI DSS, GDPR, and other relevant standards)
- Business continuity planning

**Goals:**

- Assess current security controls and compliance posture.
- Identify risks and vulnerabilities within the IT infrastructure.
- Ensure compliance with PCI DSS, GDPR, and other regulations.
- Provide actionable recommendations to enhance cybersecurity measures.

---

## 2. Controls and Compliance Checklist

| Control Category | Control Item | Compliant (Yes/No) | Notes/Recommendations |
|---|---|---|---|
| **Access Control** | Role-based access control (RBAC) enforced | No | Implement least privilege access to protect sensitive data. |
| | Multi-factor authentication (MFA) implemented | No | Enforce MFA for all critical system access. |
| **Network Security** | Firewalls and intrusion detection systems (IDS) in place | Partially | Install IDS to monitor network traffic. |
| | Secure Wi-Fi networks with WPA3 | No | Upgrade Wi-Fi security to WPA3 for stronger encryption. |
| **Data Protection** | Encryption for stored customer data | No | Apply AES-256 encryption for all sensitive information. |
| | Secure backup storage with redundancy | No | Implement encrypted and geographically redundant backups. |
| **Regulatory Compliance** | PCI DSS requirements met for payment processing | No | Implement encryption and secure payment processing protocols. |
| | GDPR compliance for EU customers | No | Develop clear data protection policies and obtain consent. |

| | | | |
|---|---|---|---|
| **Incident Response** | Incident response plan established | No | Develop, document, and test an incident response plan. |
| | Regular security training for employees | No | Conduct mandatory cybersecurity awareness training. |
| **Business Continuity** | Disaster recovery plan documented | No | Develop and test a business continuity and disaster plan. |
| | Legacy system monitoring and scheduled updates | No | Implement routine maintenance schedules for legacy systems. |
| **Physical Security** | CCTV surveillance and access control measures | Yes | Regularly review camera footage and update security policies. |
| | Fire detection and prevention systems in place | Yes | Ensure regular maintenance and compliance with fire codes. |

---

**3. Risk Assessment and Recommendations**

**Risk Score: 8/10 (High Risk)**

Current security gaps expose Botium Toys to compliance violations, data breaches, and financial penalties. Immediate action is required to mitigate these risks.

**Key Recommendations:**

1. **Access Control Enhancements:**
    - Enforce RBAC and least privilege access principles.
    - Require MFA for all employees accessing critical systems.
2. **Data Security Improvements:**
    - Encrypt all customer and internal business data.
    - Implement a centralized password management system.
3. **Regulatory Compliance Measures:**
    - Ensure adherence to PCI DSS and GDPR through regular audits.
    - Appoint a Data Protection Officer (DPO) to oversee compliance.
4. **Incident Response and Business Continuity:**
    - Develop an incident response plan and conduct regular breach simulations.
    - Implement automated failover and secure backup solutions.
5. **Physical Security Reinforcements:**
    - Restrict access to IT infrastructure with biometric authentication.
    - Improve surveillance monitoring and physical asset security.

---

**Conclusion:** The audit reveals substantial security gaps that must be addressed immediately to protect Botium Toys' assets and customer data. Strengthening access controls, enforcing encryption, ensuring regulatory compliance, and improving incident response capabilities will significantly enhance the company's cybersecurity posture and resilience against threats.